Taller Autenticación y Autorización

La empresa **EventHub Solutions** se encuentra en el proceso de modernización de su plataforma para la gestión, promoción y comercialización de eventos y conferencias tecnológicas. Como parte de su nueva arquitectura, se requiere desacoplar el cliente (*frontend* web y móvil) de la lógica de negocio mediante una API RESTful.

Durante la fase de análisis se han identificado requerimientos de seguridad y control de acceso críticos:

1. **Exposición de catálogo abierto:** El público general debe poder explorar la oferta de eventos sin necesidad de contar con una cuenta activa.
2. **Acceso e identidad:** La aplicación cliente debe consumir servicios protegidos sin depender de sesiones tradicionales basadas en cookies de navegador. Toda interacción protegida debe respaldarse con *tokens* criptográficos.
3. **Protección de la propiedad del recurso (Integridad de Eventos):** Se presentan múltiples organizadores en la plataforma. Un problema recurrente en versiones anteriores era que un organizador autenticado podía enviar peticiones HTTP y alterar o cancelar eventos pertenecientes a otros organizadores. El nuevo *backend* debe garantizar a nivel de modelo que únicamente el organizador propietario de un evento tenga privilegios para modificarlo, rechazando cualquier intento de manipulación no autorizada.
4. **Gobierno y confidencialidad financiera:** La información sobre el balance de ingresos, recaudo total y métricas globales de la plataforma solo puede ser accedida por usuarios con privilegios de Administrador Global.

Tu responsabilidad es diseñar e implementar la API en Laravel, estableciendo las capas de autenticación, control de acceso basado en roles (*Gates*) y autorización de recursos (*Policies*) que satisfagan los requerimientos del negocio.

Requisitos Funcionales

Módulo 1: Identidad y Autenticación

- **RF 1.1 — Inicio de Sesión:** El sistema debe proveer un *endpoint* (POST /api/login) que reciba credenciales (email y password). Si las credenciales son válidas, debe emitir y retornar un token de acceso criptográfico de tipo Bearer. Si son incorrectas, debe denegar el acceso.
- **RF 1.2 — Consulta de Perfil:** El sistema debe proveer un *endpoint* (GET /api/perfil) que permita al usuario autenticado consultar los datos de su cuenta.

Universidad Autónoma de Bucaramanga – UNAB. NIT 890.200.499-9 | VIGILADA MINEDUCACIÓN
Institución con Acreditación Institucional de Alta Calidad según Resolución 012987 del 31 de julio de 2023
del Ministerio de Educación Nacional vigente por 6 años.

Módulo 2: Catálogo y Gestión de Eventos (Autorización por *Policy*)

- **RF 2.1 — Consulta Pública de Eventos:** El sistema debe permitir a cualquier cliente listar los eventos registrados (GET /api/eventos) sin exigir autenticación previa. La respuesta debe incluir los datos básicos del evento y el nombre del organizador responsable.
- **RF 2.2 — Modificación de Eventos:** El sistema debe permitir la actualización de eventos (PUT /api/eventos/{id}) teniendo en cuenta las restricciones de cada campo de datos.
- **RF 2.3 — Verificación de Propiedad del Evento:** Antes de proceder con la modificación, el sistema debe comprobar de forma estricta que el usuario autenticado sea el mismo que figura como creador (user_id) del evento. Si la verificación falla, la operación debe ser rechazada.

Módulo 3: Métricas y Reportes Globales (Autorización por *Gate*)

- **RF 3.1 — Reporte Financiero y de Plataforma:** El sistema debe proveer un *endpoint* (GET /api/admin/metricas) para consultar el total consolidado de eventos y el monto global recaudado por la plataforma.
- **RF 3.2 — Restricción de Nivel Administrativo:** El acceso a este reporte debe estar restringido exclusivamente a usuarios que posean el rol de administrador.

Requisitos No Funcionales

Seguridad y Mecanismos de Autenticación

- **RNF 1.1 — Autenticación sin estado:** La emisión e inspección de tokens debe implementarse haciendo uso de Laravel Sanctum.
- **RNF 1.2 — Gestión de contraseñas:** Las contraseñas deben almacenarse de forma segura mediante algoritmos de hash unidireccionales.
- **RNF 1.3 — Protección de rutas:** Los *endpoints* protegidos deben estar encapsulados bajo el middleware de autenticación provisto por Sanctum.

Arquitectura de Autorización y Desacoplamiento

- **RNF 2.1 — Autorización granular de modelos:** La lógica que determina si un usuario puede modificar un evento debe estar encapsulada en una *Policy*. Los modelos no deben incluir validaciones manuales condicionales. La validación debe realizarse a través de los mecanismos de autorización de Laravel.

- **RNF 2.2 — Autorización global:** La restricción para el módulo de métricas administrativas debe implementarse mediante un *Gate* lógico registrado en el proveedor de servicios de la aplicación (AppServiceProvider), desacoplando la regla del controlador.

Estándares de la API REST y Manejo de Errores HTTP

- **RNF 3.1 — Respuestas:** La API debe responder estrictamente en formato JSON y apegarse a los códigos de estado HTTP estándar:
  - **200 OK:** Consultas y actualizaciones exitosas.
  - **401 Unauthorized:** Peticiones a rutas protegidas sin *token*, con *token* inválido o credenciales erróneas en *login*.
  - **403 Forbidden:** Peticiones de usuarios correctamente autenticados que no superan las reglas del *Gate* o de la *Policy*.
  - **422 Unprocessable Content:** Peticiones con errores en las reglas de validación de datos.

Modelo de Datos

Tabla users

- **id:** Clave primaria autoincremental.
- **name:** Cadena de texto (obligatoria – máximo 100 caracteres).
- **email:** Cadena de texto única (obligatoria – formato email – máximo 150 caracteres).
- **password:** Cadena de texto cifrada (obligatoria).
- **role:** Cadena de texto (obligatoria) con valor por defecto “asistente” (valores permitidos: “admin”, “organizador”, “asistente”).
- **timestamps:** Marcas de tiempo de creación y actualización.

Tabla eventos

- **id:** Clave primaria autoincremental.
- **user_id:** Clave foránea que referencia a la tabla *users* (obligatoria).
- **titulo:** Cadena de texto con el nombre del evento (obligatoria – máximo 100 caracteres).
- **descripcion:** Texto largo con la sinopsis o detalles del evento (opcional).
- **cupo_maximo:** Valor entero (obligatoria – mayor que cero).
- **timestamps:** Marcas de tiempo de creación y actualización.

Datos Semilla

El proyecto debe incluir un *seeder* configurado para poblar la base de datos con los siguientes datos de prueba:

- Un usuario con rol admin.
- Dos usuarios con rol organizador (por ejemplo, Organizador A y Organizador B).
- Un usuario con rol asistente.
- Al menos un evento registrado a nombre del Organizador A.

Formato y Condiciones de Entrega

- **Repositorio:** Enlace a un repositorio público en GitHub enviado a través de la plataforma institucional TEMA.
- **Documentación (README.md):** Instrucciones de instalación y ejecución del proyecto (migraciones, seeders y endpoints).

Universidad Autónoma de Bucaramanga – UNAB. NIT 890.200.499-9 | VIGILADA MINEDUCACIÓN
Institución con Acreditación Institucional de Alta Calidad según Resolución 012987 del 31 de julio de 2023
del Ministerio de Educación Nacional vigente por 6 años.